

OWASP

Ataque: Cross-Site Scripting (XSS)

XSS es un ataque en el que un atacante logra insertar código JavaScript malicioso en una página web. Cuando otro usuario entra a esa página, su navegador ejecuta ese código sin darse cuenta.

Esto puede ser peligroso porque el atacante puede robar información, como cookies o datos del usuario, o incluso hacerse pasar por él dentro del sistema.

¿Cómo se puede prevenir?

Se puede prevenir validando y limpiando los datos que ingresan los usuarios, evitando que se inserte código malicioso.

También se pueden usar cookies con la propiedad HttpOnly, para que no puedan ser leídas desde JavaScript.

Otra forma es usar buenas prácticas como no mostrar directamente datos sin validarlos.

CORS

CORS es una política de seguridad que tienen los navegadores para evitar que una página web haga peticiones a otro dominio sin permiso.

En este proyecto usamos CORS porque el servidor puede recibir peticiones desde diferentes orígenes, como localhost u otros dominios. Si no se configura, el navegador bloquea las peticiones aunque el servidor sí responda.

Por eso se usa el middleware cors en Node, para permitir que ciertos dominios puedan acceder al servidor. En desarrollo se puede permitir todo, pero en producción se deben especificar los dominios permitidos para mayor seguridad.